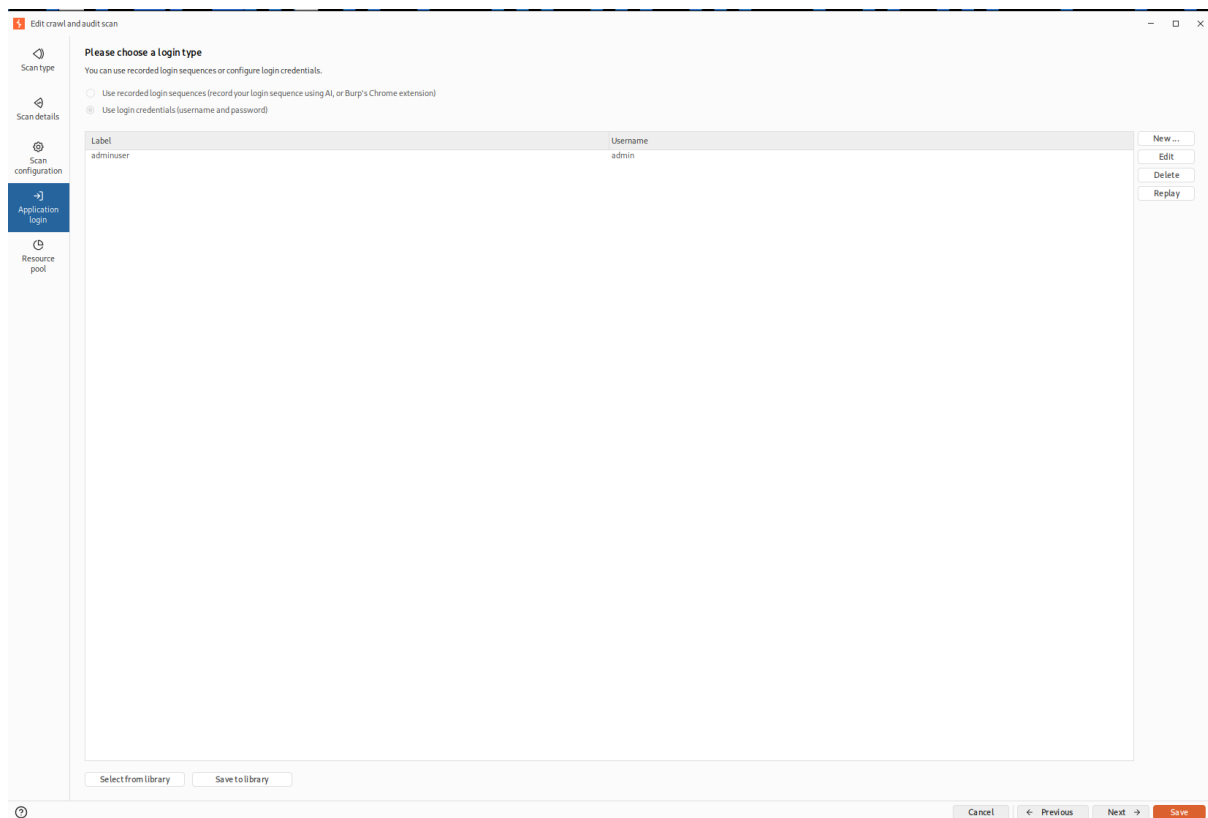


## 1. Define application login

1. Open Burp Suite Professional and create a new **Crawl and Audit scan** from the Dashboard.
2. In the left pane of the scan wizard, select **Application login**.
3. Choose **Use login credentials (username and password)**.
4. Click **New...** on the right to create a login profile.
5. Enter a **label** (for example, `adminuser`) and the **username** (for example, `admin`) plus the corresponding password.
6. Save the login profile; it now appears in the list and can be reused across scans.
7. Click **Next** to continue with the scan configuration.



## 2. Configure crawl behaviour

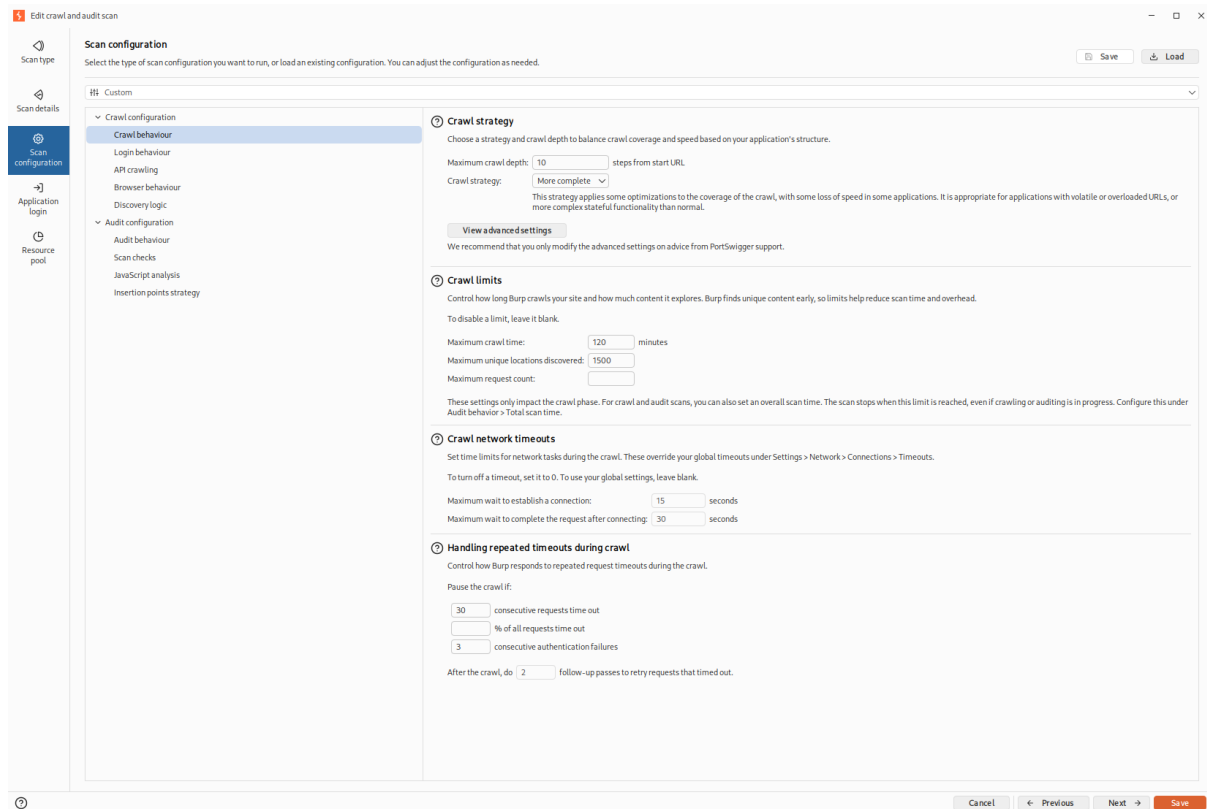
1. In the scan wizard, go to **Scan configuration, Crawl configuration, Crawl behaviour**.
2. Under **Crawl strategy**, set:
  - o **Maximum crawl depth:** 10 steps from the start URL.
  - o **Crawl strategy:** More complete.

This instructs Burp to favour coverage over speed while keeping depth bounded.

3. Under **Crawl limits**, set:

- **Maximum crawl time:** 120 minutes.
  - **Maximum unique locations discovered:** 1500.
  - Leave **Maximum request count** blank if you do not want a hard request cap.
4. Under **Crawl network timeouts**, configure:
    - **Maximum wait to establish a connection:** 15 seconds.
    - **Maximum wait to complete the request after connecting:** 30 seconds.
  5. Under **Handling repeated timeouts during crawl**, set:
    - Pause the crawl if 30 **consecutive request time outs**.
    - Pause if 30 percent of all requests time out.
    - Pause if 3 **consecutive authentication failures** occur.
    - After the crawl, perform 2 follow-up passes to retry operations that timed out.
  6. Click **Save** (top right) to preserve this custom crawl profile if you plan to reuse it.

This configuration balances coverage with stability, preventing runaway scans on noisy or unstable lab targets.

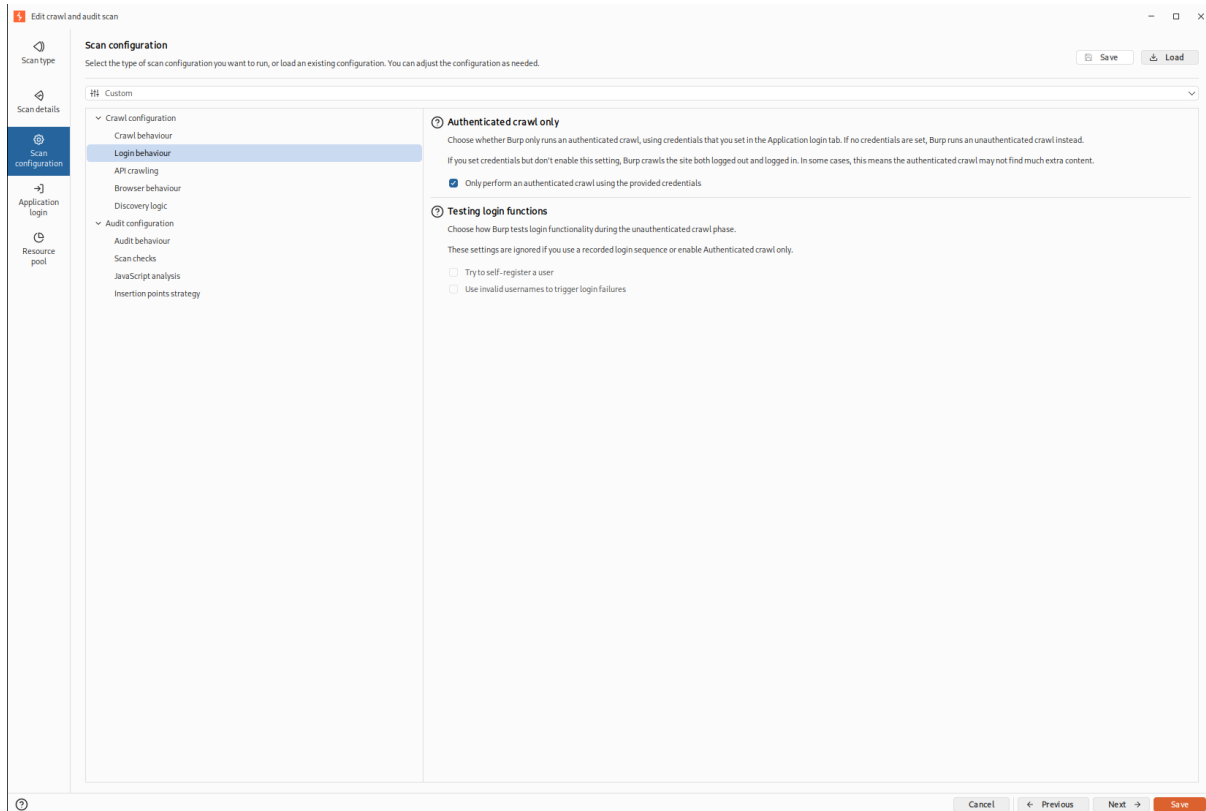


### 3. Configure login behaviour for the crawl

1. In the same **Scan configuration** section, select **Login behaviour** under **Crawl configuration**.
2. Enable **Authenticated crawl only** by selecting:
  - **Only perform an authenticated crawl using the provided credentials.**

3. Leave the **Testing login functions** options unchecked (self-registration and invalid usernames), as they are not required for controlled lab environments and may introduce noise.
4. Click **Save** or **Next** to continue.

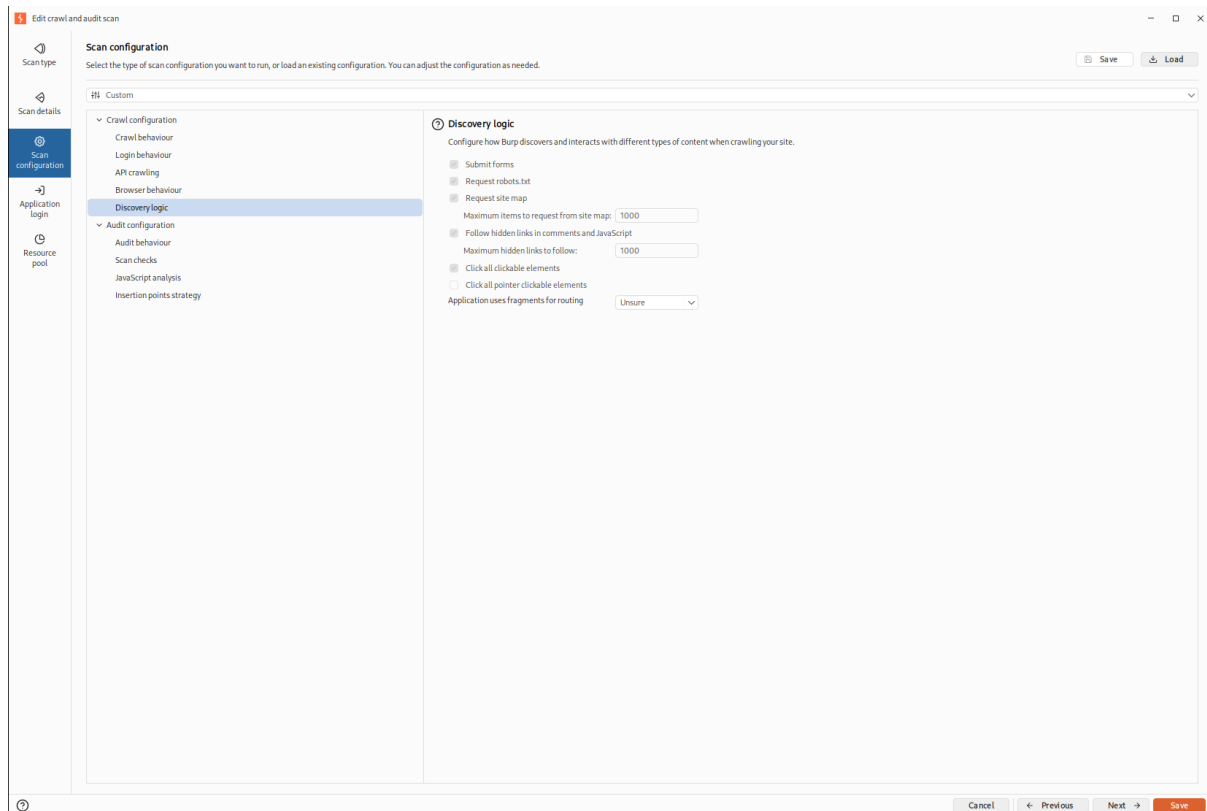
This ensures the crawler uses the credentials defined in the Application login step and focuses on the authenticated attack surface.



## 4. Configure discovery logic

1. Under **Crawl configuration**, select **Discovery logic**.
2. Enable or confirm the following options to make crawling thorough:
  - **Submit forms**: allow Burp to submit simple forms during discovery.
  - **Request robots.txt**: fetch any robots file for hints about disallowed paths.
  - **Request site map**: request XML sitemaps where available.
3. Set limits:
  - **Maximum items to request from site map**: 1000.
  - **Maximum hidden links to follow** (for comments and JavaScript): 1000.
4. Decide whether Burp should **click all clickable elements** or only those relevant; for typical labs you can leave this unchecked to avoid excessive interaction.
5. Set **Application uses fragments for routing** to **Unsure** unless you know the application is single-page and uses URL fragments heavily; adjust to **Yes** for modern SPAs as needed.
6. Save any changes.

These options tune how Burp discovers endpoints and hidden content, which directly affects DAST coverage.



## 5. Configure audit behaviour (active scan)

1. Under **Audit configuration**, select **Audit behaviour**.
2. In **Audit strategy**:
  - Set **Audit speed** to **Thorough** to maximise coverage and depth of checks.
  - Set **Audit accuracy** to **Minimize false negatives**, favouring higher confidence at the expense of more requests.
3. Enable or review additional audit options:
  - **Skip checks unlikely to be effective**: reduce unnecessary traffic.
  - **Automatically maintain session** (for non-audit-only scans): ensure session continuity.
  - **Follow redirections when necessary**.
  - **Allow crawl and audit phases to run in parallel**: if your environment can handle the load.
4. In **Total scan time**, optionally set a **Maximum scan time** (in minutes) to cap long-running scans for lab sessions; leave blank for no global time limit.
5. In **Issue noise reduction**, enable **Consolidate frequently occurring passive issues** to group repeated findings and simplify reporting.
6. In **Audit network timeouts**, set:
  - **Maximum time to establish a connection**: 10 seconds.
  - **Maximum time to complete the request after connecting**: 60 seconds.
7. In **Handling repeated timeouts during audit**, set thresholds, for example:

- If 5 consecutive audit checks fail, skip remaining checks in the current insertion point.
  - If 5 consecutive insertion points fail, skip remaining insertion points and mark the audit item as failed.
  - Pause the audit if 60 **consecutive audit items** fail or if a certain percentage of audit items fail (for example, half).
  - After each audit phase, perform 2 follow-up passes to retry failed operations.
8. Save the custom audit configuration for reuse in future scans.

These settings control the trade-off between thoroughness, performance, and resilience to unstable lab targets.

**Edit crawl and audit scan**

**Scan configuration**  
Select the type of scan configuration you want to run, or load an existing configuration. You can adjust the configuration as needed.

Save Load

Custom

**Audit behaviour**

**Audit strategy**  
These settings enable you to control audit coverage and speed based on your application's structure.  
Control how many requests Burp sends and how deeply it checks for vulnerabilities.  
Audit speed: Thorough  
Control how many times Burp retries tests to confirm issues. Minimizing false negatives means fewer retries; minimizing false positives means more retries.  
Audit accuracy: Minimize false negatives  
☐ Skip checks unlikely to be effective  
☒ Automatically maintain session (doesn't apply to audit-only scans)  
☒ Follow redirections when necessary  
☒ Allow crawl and audit phases to run in parallel

**Total scan time**  
Limit the total run time for a scan. When the time limit is reached, the scan stops immediately, even if the crawl or audit isn't finished.  
This doesn't apply to audit-only scans.  
Maximum scan time: 10 minutes

**Issue noise reduction**  
Reduce noise by grouping repeated passive issues in the scan results.  
☒ Consolidate frequently occurring passive issues

**Audit network timeouts**  
Set time limits for network tasks during the audit. These override your global timeout settings under Settings > Network > Connections > Timeouts.  
To turn off a timeout, set it to 0. To use your global settings, leave blank.  
Maximum time to establish a connection: 10 seconds  
Maximum time to complete the request after connecting: 60 seconds

**Handling repeated timeouts during audit**  
Control how Burp responds to repeated timeouts during the audit.  
If 5 consecutive audit checks fail, skip remaining checks in the current insertion point  
If 5 consecutive insertion points fail, skip remaining insertion points, and flag audit item as failed  
Pause the audit if:  
60 consecutive audit items fail  
% of audit items fail  
On completion of each audit phase, do 2 follow-up passes to retry failed operations

Cancel Previous Next Save

## 6. Finalise and save the scan configuration

1. Review all tabs under **Scan configuration** (Crawl behaviour, Login behaviour, Discovery logic, Audit behaviour) to ensure they match your lab policy.
2. At the top right of the scan configuration page, click **Save** and give the configuration a name.
3. Click **Next**, verify **Scan type** and **Scan details**, then start the scan from the wizard.

This saved profile becomes your standard **Burp Suite Professional scanner configuration** for the dissertation, ensuring all experiments are reproducible and consistently scoped.